

Field	Description
Case ID:	CS-2025-005
Case Type:	Hands-on keyboard attack was launched from a compromised account (attack disruption)
Reported by:	Windows Defender
Analyst:	Ali YILMAZ
Date:	2025-10-16
Severity:	High
Status:	Closed
Environment:	Production

Case Title

Hands-on keyboard attack was launched from a compromised account (attack disruption)

Case ID

- T1078 - Valid Accounts
- T1059.001 - Command and Scripting Interpreter: PowerShell
- T1003 - OS Credential Dumping (Mimikatz)
- T1057 - Process Discovery
- T1021 - Remote Services (Lateral Movement)

Detection Source

Microsoft Defender for Endpoint - Behavioral alert chain correlated under *Hands-on-Keyboard Attack from a Compromised Account*.

Incident Summary

Defender detected multiple suspicious activities executed by a legitimate user account (**Esarpiel**) on host **dedcs-01**.

The account performed command-line actions, credential dumping, and system reconnaissance, indicating **hands-on-keyboard attacker activity**.

Automated remediation was triggered to contain the compromised account and isolate the affected device.

MITRE ATT&CK

- T1078 - Valid Accounts
- T1059.001 - Command and Scripting Interpreter: PowerShell
- T1003 - OS Credential Dumping (Mimikatz)
- T1057 - Process Discovery
- T1021 - Remote Services (Lateral Movement)

Investigation Steps

- Reviewed Defender *Attack Story* timeline:

Suspicious Process Discovery

Malicious Credential Theft Tool Execution (Mimikatz.exe)

Suspicious Sequence of Exploration Activities

- Examined the **incident graph** linking the user *Esarpiel* to host *dedcs-01* and associated processes.
- Verified PowerShell commands containing -EncodedCommand (indicating script-based execution).
- Identified *mimikatz.exe* used for credential theft and *explorer.exe* used during manual interaction.
- Confirmed the alert chain represents real hands-on actions, not automation.
- Checked Azure AD sign-in logs for unusual login patterns or IP addresses.

Evidence

- Screenshot of Microsoft Defender *Attack Story* and *Incident Graph* showing PowerShell and Mimikatz activity.
- Process list:

powershell.exe -EncodedCommand RwbIAH...

mimikatz.exe

explorer.exe
- Alerts timeline (July 30, 2025): process discovery → credential theft → exploration sequence.

Recommended Actions

- Disable the compromised user account immediately.
- Force password reset and revoke active sessions.
- Isolate the host *dedcs-01* from the network.

- Escalate to Tier-2 for full forensic review and credential exposure analysis.
- Review other sign-ins and endpoints for the same account or IP origin.

Organizational / HR Actions

- Notify affected user and security management.
- Enforce MFA and conditional access policies.
- Conduct short awareness refresher on credential hygiene and phishing prevention.

Business Impact

Potential exposure of internal credentials and privilege escalation risk.

If not contained, attacker could gain domain-wide access or launch ransomware through lateral movement.

Quick Hunting Snippets

DeviceProcessEvents

| where AccountName == "<username>"

| where Timestamp >= ago(1d)

| project Timestamp, DeviceName, InitiatingProcessFileName, FileName,
ProcessCommandLine, ReportId

| order by Timestamp desc

DeviceProcessEvents

| where FileName in ("mimikatz.exe","sekurlsa.exe") or ProcessCommandLine has "sekurlsa"
or ProcessCommandLine has "logonpasswords"

| project Timestamp, DeviceName, AccountName, FileName, ProcessCommandLine,
ReportId

| order by Timestamp desc

Result / Assessment

True Positive – Compromised Account

The user account was hijacked and used interactively by an attacker to perform credential dumping and lateral movement preparation.

Defender automatically executed account containment to prevent further spread.

The screenshot displays the Microsoft Defender Security Center interface. The left sidebar contains navigation options: Home, Exposure management, Investigation & response, Threat intelligence, Assets, Microsoft Sentinel, Identities, Endpoints, Email & collaboration, Cloud apps, and Cases. The main content area shows an incident titled "Hands-on keyboard attack was launched from a compromise...". The incident is categorized as High, Active, and Unassigned, with tags for Ransomware, Lateral Movement, and Attack Disruption. A warning message states: "Attention! Attack disruption initiated a contain user action on a compromised account. For more details, select the Assets > Users tab or go to the Action center." Below this, a message indicates that Go Hunt queries now default to a time range starting from the incident's start time up to the execution time. The incident details are shown under the "Attack story" tab, which includes a list of alerts: "Suspicious Process Discovery" (Jul 30, 2025 4:37 PM), "Malicious credential theft tool execution detected" (Jul 30, 2025 4:50 PM), and "Suspicious sequence of exploration activities" (Jul 30, 2025 9:35 PM). The "Incident graph" shows a network of nodes including "Esarpiel", "dedcs-01", and "36 Files". The "5 Processes" section lists: "powershell.exe" -EncodedCommand RwbIAHQALQBQAHL..., "mimikatz.exe", "powershell.exe" -EncodedCommand RwbIAHQALQBQAHL..., "Explorer.EXE", and "mimikatz.exe".

Hands-on keyboard attack was launched from a compromise...

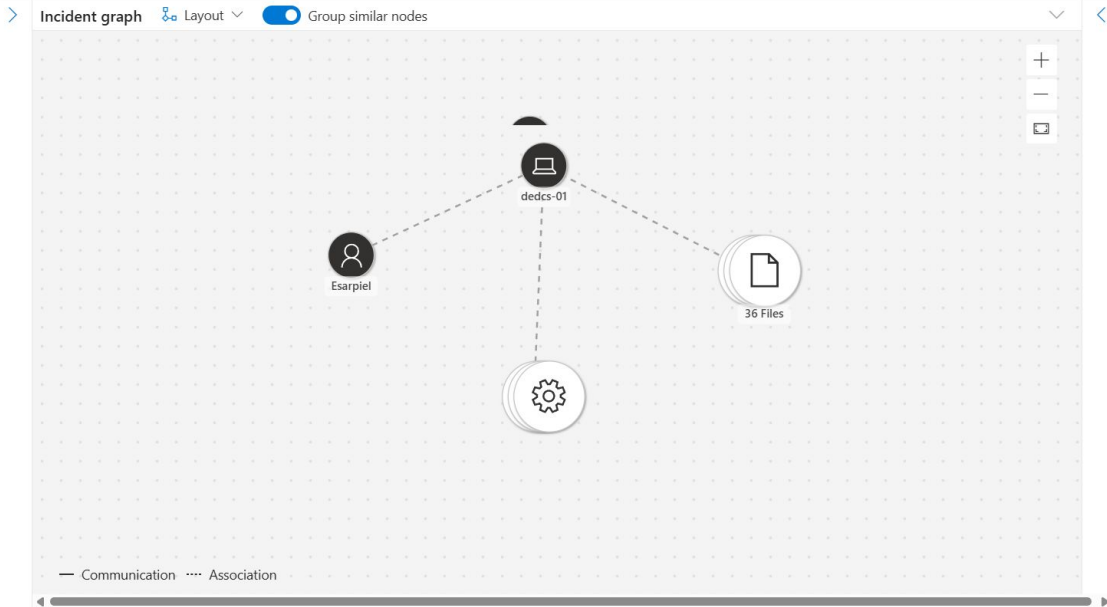
[Manage incident](#) [Tasks](#) ...

High Active Unassigned Ransomware Lateral Movement Attack Disruption

Attention! Attack disruption initiated a contain user action on a compromised account. For more details, select the Assets > Users tab or go to the [Action center](#).

Go Hunt queries launched from the entity menu now default to a time range starting from the incident's start time up to the execution time. For incidents older than 30 days, the query defaults to last 30-day.

Attack story Alerts (27) Activities Assets (2) Investigations (1) Evidence and Response (91) Summary



Microsoft Defender Search

Home Exposure management Investigation & response Incidents & alerts Hunting Advanced hunting Custom detection rules Actions & submissions Partner catalog Threat intelligence Assets Microsoft Sentinel Identities

Advanced hunting

New query* + |

Schema Functions Search Favorites Alerts & behaviors Apps & identities

Run query Last 7 days Save Share link Create summary rule

Query

```

1 DeviceProcessEvents
2 | where Filename in ("mimikatz.exe","sekurlsa.exe") or ProcessCommandLine has "sekurlsa" or ProcessCor
3 | project Timestamp, DeviceName, AccountName, FileName, ProcessCommandLine, ReportId
4 | order by Timestamp desc
5

```

Getting started Results Query history

Export 0 items Search 00:00.880 Low

Filters: Add filter

Microsoft Defender

Search

Home

Exposure management

Investigation & response

Incidents & alerts

Hunting

Advanced hunting

Custom detection rules

Actions & submissions

Partner catalog

Threat intelligence

Assets

Microsoft Sentinel

Identities

Advanced hunting

Selected workspace: mssentinel

Help resources

New query*

Schema

Functions

Search

Favorites

Alerts & behaviors

Apps & identities

Run query

Set in query

Save

Share link

Create summary rule

Query

1 DeviceProcessEvents

2 | where AccountName == "<username>"

3 | where Timestamp >= ago(1d)

4 | project Timestamp, DeviceName, InitiatingProcessFileName, FileName, ProcessCommandLine, ReportId

5 | order by Timestamp desc

6

Getting started

Results

Query history

Export

0 items

Search

00:00.909

Low

Filters

Add filter

MITRE | ATT&CK

Matrices

Tactics

Techniques

Defenses

CTI

Resources

Benefactors

Blog

Search

ATT&CKcon 6.0 is coming October 14-15 in McLean, VA and live online. Tickets are available now!

TECHNIQUES

Valid Accounts

Default Accounts

Domain Accounts

Local Accounts

Cloud Accounts

Wi-Fi Networks

Execution

Persistence

Privilege Escalation

Defense Evasion

Credential Access

Discovery

Lateral Movement

Collection

Command and Control

Home > Techniques > Enterprise > Valid Accounts

Valid Accounts

Sub-techniques (4)

Adversaries may obtain and abuse credentials of existing accounts as a means of gaining Initial Access, Persistence, Privilege Escalation, or Defense Evasion. Compromised credentials may be used to bypass access controls placed on various resources on systems within the network and may even be used for persistent access to remote systems and externally available services, such as VPNs, Outlook Web Access, network devices, and remote desktop.^[1] Compromised credentials may also grant an adversary increased privilege to specific systems or access to restricted areas of the network. Adversaries may choose not to use malware or tools in conjunction with the legitimate access those credentials provide to make it harder to detect their presence.

In some cases, adversaries may abuse inactive accounts: for example, those belonging to individuals who are no longer part of an organization. Using these accounts may allow the adversary to evade detection, as the original account user will not be present to identify any anomalous activity taking place on their account.^[2]

The overlap of permissions for local, domain, and cloud accounts across a network of systems is of

ID: T1078

Sub-techniques: T1078.001, T1078.002, T1078.003, T1078.004

Tactics: Defense Evasion, Persistence, Privilege Escalation, Initial Access

Platforms: Containers, ESXi, IaaS, Identity Provider, Linux, Network Devices, Office Suite, SaaS, Windows, macOS

Contributors: Jon Sternstein, Stern Security, Mark Wee; Menachem Goldstein; Netskope; Praetorian; Prasad Somasamudram, McAfee; Sekhar Sarukkai, McAfee; Syed Ummar Farooq, McAfee; Yossi Weizman, Azure Defender Research Team

Version: 2.8